

■ ■ AWS IAM Complete Study Guide

SAA-C03 Certification Exam

Exam Target	AWS SAA-C03
Exam Date	July 29, 2026
Domain	Design Secure Architectures (30%)
Topics Covered	13 IAM Topics — Complete

■ Topics Covered

#	Topic	Status
1	IAM Fundamentals — Users, Groups, Roles, Policies	■
2	Policy Evaluation Logic	■
3	IAM Conditions	■
4	Permission Boundaries	■
5	Service Control Policies (SCPs)	■
6	STS — Security Token Service	■
7	Federation — SAML 2.0 + Cognito	■
8	Credential Types	■
9	IAM Roles for Services	■
10	IAM Access Analyzer	■
11	Policy Simulator + CloudTrail	■
12	Session Policies	■
13	Identity Center (SSO)	■

1. IAM Fundamentals

■ The Bank Analogy

Think of AWS as a bank. IAM controls who can enter, what they can do, and which rooms they can access.

The 4 Core Identities

Identity	What it is	Real World
IAM User	Permanent human identity with long-term credentials	Permanent bank employee with a company ID
IAM Group	Collection of users sharing the same permissions	The 'Tellers' department — all tellers get same access
IAM Role	Temporary identity for services or cross-account access	Visitor pass — temporary, specific access, auto-expires
Root User	All-powerful account owner — use only for billing	The bank owner — has master key to everything

Policy Types

Policy Type	Attached To	Grants Permissions?	Example
Identity-based	User / Group / Role	■ Yes	Allow s3:GetObject
Resource-based	S3, Lambda, SQS etc	■ Yes	S3 bucket policy
Permission Boundary	User / Role	■ No — ceiling only	Max allowed: s3, ec2
SCP	AWS Account (org)	■ No — ceiling only	Block non-us-east-1
Session Policy	One STS session	■ No — restricts only	Temp scope down

2. Policy Evaluation Logic

The Golden Rule

■ EXAM TRAP: Explicit Deny ALWAYS wins — no exceptions.

Evaluation Order

Step	Check	Result
1	Explicit DENY in any policy?	■ DENIED — stop here
2	Explicit ALLOW in any policy?	Continue to next check
3	Resource policy allows?	■ ALLOWED
4	Nothing says yes?	■ DENIED (implicit deny)

Full Evaluation Stack (Request comes in)

Layer	Applied By	Scope
1. SCP	Org Admin	Entire AWS Account
2. Session Policy	Developer	One STS Session
3. Permission Boundary	IAM Admin	One User or Role
4. IAM Policy	IAM Admin	Specific permissions
5. Resource Policy	Resource Owner	Specific resource

■ KEY RULE: Only IAM Policy and Resource Policy GRANT permissions. Everything else only restricts.

3. IAM Conditions

Conditions are "IF" statements in policies. They narrow the scope of when a policy applies.

Top 5 Conditions to Know

Condition	Operator	Exam Keyword
IP Restriction	IpAddress: aws:SourceIp	"only from office" / "specific IP"
MFA Required	Bool: aws:MultiFactorAuthPresent	"must use MFA" / "require MFA"
Region Lock	StringEquals: aws:RequestedRegion	"specific region only"
Time Window	DateGreaterThan/DateLessThan	"business hours only"
Tag-Based	StringEquals: ec2:ResourceTag/Env	"tagged resources" / "dev only"

■ EXAM TRAP: Use BoolIfExists (not Bool) for MFA — if the key is absent, Bool skips the check entirely and grants access anyway.

4. Permission Boundaries

The Salary Analogy: Company rule says max salary is \$80k. That does NOT mean everyone gets \$80k. Your actual salary (IAM Policy) still determines what you get — it just can never exceed the ceiling.

The Formula

Effective Permissions = IAM Policy AND Permission Boundary

Three Scenarios

Scenario	Policy Says	Boundary Says	User Gets
A	s3:*, ec2:*	s3:*, ec2:*, rds:*	s3:*, ec2:* (policy is smaller)
B	s3:*, rds:*	s3:*, ec2:*	s3:* only (intersection)
C	s3:*, ec2:*	s3:*, ec2:* + Deny by SCP	s3:*, ec2:* minus SCP denial

Boundary vs SCP vs Session Policy

	Permission Boundary	SCP	Session Policy
Set by	IAM Admin	Org Admin	Developer
Applies to	One User/Role	Entire Account	One STS Session
Grants?	■ No	■ No	■ No
Keyword	delegate safely	entire account	one-time restrict

■ EXAM TRAP: Boundary alone does nothing. A user with only a boundary and no IAM Policy = zero access.

5. STS — Security Token Service

The Arcade Token Analogy: You give \$20 cash → get back 20 tokens → tokens work inside the arcade → tokens expire at closing time. STS gives temporary AWS credentials the same way.

The 4 STS Actions

Action	Who Uses It	When	Example
AssumeRole	Any identity switching roles	Cross-account, services	Account A accessing Account B
AssumeRoleWithWebIdentity	App users via Google/Facebook	Mobile/web apps	CertiPrepAI users via Google
AssumeRoleWithSAML	Corporate employees via AD	Enterprise SSO	Hospital staff via Active Directory
GetSessionToken	IAM users needing MFA	Sensitive actions	Admin deleting resources with MFA

Token Structure

Every STS token has 3 parts: Access Key ID + Secret Access Key + Session Token. All 3 must be present. Missing the Session Token = access denied.

■■ EXAM TRAP: STS is global — not region-specific. You cannot revoke a token mid-flight. Wait for expiry or revoke the role's trust policy.

6. Federation — SAML 2.0 + Cognito

Federation = Use your existing login from somewhere else to access AWS. No IAM user needed.

SAML 2.0 vs Web Identity (Cognito)

	SAML 2.0 (AD FS)	Web Identity (Cognito)
Who uses it	Company employees	App end users (customers)
Identity source	Microsoft Active Directory	Google, Facebook, Apple, Amazon
STS action	AssumeRoleWithSAML	AssumeRoleWithWebIdentity
AWS service	IAM Identity Provider	Amazon Cognito
Use case	Corporate SSO	Mobile/web app users
Scale	Hundreds of employees	Millions of users
Keyword	"Active Directory" "corporate"	"Google login" "mobile app"

■ EXAM TRAP: Cognito has two parts — User Pool (authentication/login) and Identity Pool (gives AWS credentials). Know which does what.

■ KEY RULE: You always still need an IAM Role. Federation changes HOW you get it, not that you need it.

7. Credential Types

Credential Type	Used By	Expires?	Risk	Use Case
Access Key + Secret Key	IAM Users	■ Never	■ High	Developer CLI access
Temporary Token (STS)	Services, apps, cross-accounts	■ Yes	■ Low	Lambda, EC2, federation
Instance Profile	EC2 only	■ Auto-rotates	■ Low	EC2 calling AWS services
Environment Variables	Apps (avoid!)	■ Never	■ Very High	■ Never use for AWS

The Golden Rule

Who needs access?	Use this
Human developer (CLI/Console)	Access Key + Secret Key (+ MFA)
AWS Service (Lambda, EC2, ECS)	IAM Role + Temporary Credentials
App users (Google/Facebook)	Cognito + IAM Role
Corporate employees (AD)	SAML + IAM Role
Cross-account access	IAM Role + AssumeRole

■■ EXAM TRAP: Never put access keys on EC2. Always use IAM Role + Instance Profile. This is the #1 most tested security best practice.

8. IAM Roles for Services

Any AWS service that needs to call another AWS service uses an IAM Role. Never an IAM User. Never hardcoded keys.

Most Common Service Roles

Service	Role Type	Common Permissions
EC2	Instance Profile	S3, DynamoDB, SSM, CloudWatch
Lambda	Execution Role	DynamoDB, S3, SNS, CloudWatch Logs
ECS	Task Role	S3, DynamoDB, Secrets Manager
CodePipeline	Service Role	S3, CodeBuild, CodeDeploy
CloudFormation	Stack Role	Whatever it needs to create
RDS	Monitoring Role	CloudWatch Enhanced Monitoring

■■ EXAM TRAP: 'Developer put access keys on EC2' is ALWAYS the wrong answer. Correct = IAM Role attached as Instance Profile.

9. IAM Access Analyzer + CloudTrail

IAM Access Analyzer

The Security Guard Analogy: Walks through all 100 storage rooms and tells you which ones have unlocked doors. It does NOT lock them — it only reports.

What it scans	S3 buckets, IAM Roles, KMS Keys, Lambda functions, SQS Queues
What it finds	Resources accessible from OUTSIDE your account or organization
Zone of Trust	Your AWS Account or entire AWS Organization
Finding types	Active (needs fix) / Archived (intentional) / Resolved (fixed)
Does it fix?	■ No — reports only. You must fix manually.

Policy Simulator vs CloudTrail

	Policy Simulator	CloudTrail
When	BEFORE the action	AFTER the action
Purpose	Test permissions	Audit and investigate
Shows	Would this be allowed?	What actually happened?
Use case	Debug policies pre-deploy	Security investigation
Keyword	"verify" "test" "before"	"who did" "audit" "investigate"

■ EXAM TRAP: CloudTrail retains logs 90 days by default. For long-term retention → store CloudTrail logs in S3.

■ Master Exam Keyword Map

When you see this on the exam → think this answer.

You see this in the exam...	Answer
Permanent human developer access	IAM User
App/service needs AWS access	IAM Role
Cross-account access	IAM Role + AssumeRole
Google/Facebook login + AWS access	AssumeRoleWithWebIdentity + Cognito
Corporate Active Directory + AWS	AssumeRoleWithSAML + AD FS
MFA required for sensitive action	GetSessionToken
Developers create users but limit what they can do	Permission Boundary
Prevent privilege escalation	Permission Boundary
Restrict entire account / all accounts in org	SCP
Even admins / root can't do it	SCP
Restrict one specific session only	Session Policy
Find S3 buckets exposed to public	IAM Access Analyzer
Who deleted/modified a resource?	CloudTrail
Test permissions before deploying	Policy Simulator
No IAM users should be created	IAM Role + STS
SSO across multiple AWS accounts	Identity Center
EC2 needs to access S3 securely	IAM Role + Instance Profile
Only from office IP address	Condition: aws:SourceIp
Must use MFA	Condition: BoolIfExists MultiFactorAuthPresent
Specific region only	Condition: aws:RequestedRegion
Tagged resources only	Condition: ec2:ResourceTag

■ ■ Top Exam Traps — IAM

1. Boundary word 'Allow' is misleading

Allow in a boundary does NOT grant access. It defines the maximum ceiling. The IAM Policy still needs to explicitly grant the permission.

2. SCPs don't affect the management account

SCPs apply to member accounts only. The root management account of the organization is exempt from SCPs.

3. Groups cannot be principals

You cannot add a Group to a resource-based policy (S3 bucket policy). Use specific users, roles, or account IDs.

4. Groups cannot contain groups

IAM Groups cannot be nested. Users can be in multiple groups but groups cannot contain other groups.

5. Bool vs BoolIfExists for MFA

Use BoolIfExists for MFA conditions. If the key is absent (non-MFA session), Bool skips the condition and grants access anyway.

6. Access keys on EC2 = always wrong

Never put access keys on EC2 instances. Always use IAM Role + Instance Profile. This is the #1 security best practice.

7. Boundary alone = zero access

A user with only a permission boundary and no IAM Policy has zero access. Boundary is a ceiling, not a floor.

8. STS tokens have 3 parts

Temporary credentials = Access Key + Secret Key + Session Token. Missing the Session Token = authentication fails.

9. CloudTrail 90-day limit

CloudTrail retains logs for 90 days by default. For compliance requiring longer retention, store logs in S3.

10. Access Analyzer does not fix

IAM Access Analyzer only finds and reports exposed resources. It never fixes them automatically.

11. Role vs Resource Policy (cross-account)

When a user needs cross-account access AND must keep original account permissions, use Resource Policy not Role assumption (Role causes you to lose original permissions).

12. SCP = ceiling not grant

Even if SCP says Allow s3:*, it does NOT grant s3 access. The IAM Policy inside the account must also allow it.

■ Quick Reference Card

Security Services Comparison

Service	What it detects	Data source
CloudTrail	API activity — who did what	AWS API calls
CloudWatch	Performance issues	Metrics and logs
GuardDuty	Threats and attacks	CloudTrail + VPC Flow Logs + DNS
Macie	Sensitive data exposure (PII)	S3 bucket contents
IAM Access Analyzer	Resources exposed outside account	Resource policies
Inspector	Vulnerabilities in EC2/containers	EC2, ECR

The 3 Ceilings

SCP (account) > Permission Boundary (user/role) > Session Policy (one session)

IAM Evaluation Formula

Effective Permissions = IAM Policy AND Boundary AND Session Policy, minus any SCP restrictions, minus any Explicit Denies

IAM — 100% Complete ■ | Next: Compute (EC2, Lambda, ECS, EKS, Elastic Beanstalk)

AWS SAA-C03 | Exam Date: July 29, 2026 | CertiPrepAI.com